Internet das coisas

Segurança no Desenvolvimento de Software

Controle de Acesso com RBAC (Role-Based Access Control) PARTE 1

Prof. Ana Beatriz Morais

SET/2026

SENAI
PELO FUTURO DO TRABALHO

O que veremos hoje

- **O que é Controle de Acesso?**
- **Autenticação vs Autorização (diferença simples)**
- **RBAC: O que são Roles (admin, user, guest)?**
- **Parte 1: Front-end**
- **Parte 2:**
    - **Armazenar role no banco de dados e no JWT**
    - **Back-end: Middleware simples para verificar role**
    - **Proteger rotas:**
        - **Admin consegue deletar, user não consegue**



Controle de Acesso

Controle de acesso

- **Método de segurança** que **regula quem pode ver ou usar** recursos em um sistema ou rede.
- Garante que **apenas usuários autorizados acessem dados**, aplicativos e/ou equipamentos.
- O objetivo é **proteger informações importantes** e evitar invasões ou vazamentos.

Autenticação vs Autorização

Autenticação vs Autorização

- **Autenticação**
  - É o processo de verificar a sua identidade.
  - Confirma quem você é.
- **Autorização**
  - Processo de conceder ou negar permissão aos recursos.
  - Define o que você pode fazer no sistema.

RBAC (Role-Based Access Control)

RBAC

- **O que significa?**
  - Controle de acesso baseado em funções.
  - É um método de segurança que restringe o acesso a sistemas de TI com base nas funções individuais de cada usuário em uma empresa.
- **Como funciona?**
  - O administrador atribui funções predefinidas (como "administrador", "gerente" ou "operador") aos colaboradores, em vez de dar permissões específicas a cada pessoa.

RBAC

- **Autorização simplificada:**
  - Ajuda a separar a autenticação (saber quem é o usuário) da autorização (o que ele pode fazer), facilitando auditorias e a segurança de dados sensíveis.
- **O que são Roles (regras) ?**
  - Roles são os papéis que representam o nível de acesso de um usuário dentro do sistema.
  - Admin: Cadastrar, visualizar, editar e excluir
  - User: Visualizar e editar os próprios dados
  - Guest: Visualizar apenas conteúdos públicos

RBAC - Exemplos Práticos de Funções no Mundo Real

- **Exemplos:**
  - Engenharia de Software:
    - Tem acesso ao GitHub, AWS e ferramentas de CI/CD.
  - Recursos Humanos (RH):
    - Pode visualizar e atualizar dados pessoais e currículos de funcionários, sem acesso a dados financeiros.
  - Financeiro / Contabilidade:
    - Pode acessar faturas, softwares de folha de pagamento e contas a receber, sem ver arquivos do RH.
  - Marketing:
    - Tem acesso a plataformas como Google Analytics, redes sociais e ferramentas de anúncios.

RBAC - Cenários de Uso por Setor

- **Exemplos:**
  - Sistemas de Saúde:
    - Médicos podem ler e editar prontuários de pacientes, enquanto a equipe administrativa visualiza apenas dados de agendamento e faturamento.
  - Aplicações Bancárias:
    - Caixas e gerentes possuem limites operacionais distintos para prevenir fraudes e cumprir normas de segurança financeira.
  - Infraestrutura em Nuvem:
    - Administradores de nuvem controlam recursos virtuais específicos (como AWS IAM) seguindo o princípio do menor privilégio.

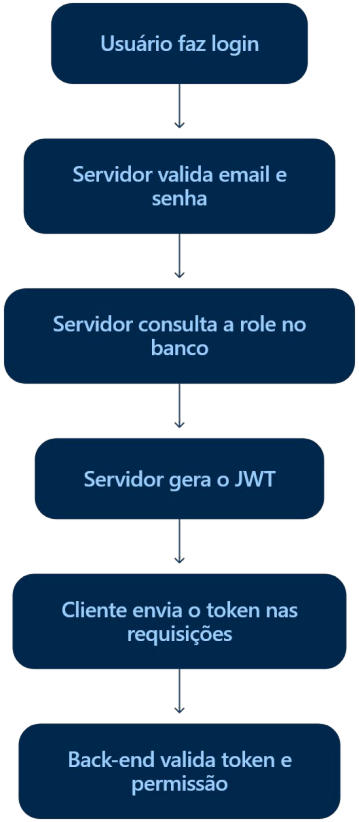
Princípio do menor privilégio

- POLP, do inglês *Principle of Least Privilege*
- **Como funciona:**
  - Acesso sob medida:
    - Cada pessoa ou aplicativo recebe permissões específicas, nem mais, nem menos.
  - Sem direitos de administrador:
    - A maioria dos funcionários não precisa de controle total do computador para trabalhar.
  - Visão de Confiança Zero:
    - O conceito faz parte de estratégias modernas de proteção, como as explicadas pela Cloudflare, onde nenhum usuário é confiado totalmente por padrão.

Importância do princípio do menor privilégio

- **Reduz danos:**
  - Se uma conta for hackeada, o invasor só consegue mexer no que aquela conta específica acessa.
- **Bloqueia vírus:**
  - Impede que um programa malicioso se espalhe facilmente por toda a rede da empresa.
- **Evita erros:**
  - Diminui a chance de alguém apagar ou alterar arquivos importantes por acidente.

Importância do princípio do menor privilégio



Parte 1: Front-end com Next.js

Parte 2: Back-end com Nodejs e Expressjs

SENAI

Serviço Nacional de Aprendizagem Industrial

PELO FUTURO DO TRABALHO

0800 048 1212 **sc.senai.br**

Rodovia Admar Gonzaga, 2765 - Itacorubi - 88034-001 - Florianópolis, SC